THE PROBLEM

72 hours, four systems, one decision

When personal data leaks, GDPR Art. 33 gives the controller 72 hours to notify the supervisory authority, and Art. 34 requires telling the affected people when the risk is high.

- Who decides: the data protection officer (DPO) or compliance lead of a small or mid-sized organisation or public body, usually alone.
- Where the facts are: the incident log, the record of processing activities, the asset and encryption register and processor contracts. Separate systems, owned by other people.
- What goes wrong: the clock runs while facts are collected by hand, and the final call is hard to justify afterwards to the authority.

Breach72 answers: notify or not, who, by when, and exactly why, with every claim linked to its source record and legal basis.

THE SOLUTION

A decision the DPO can defend

What the DPO gets

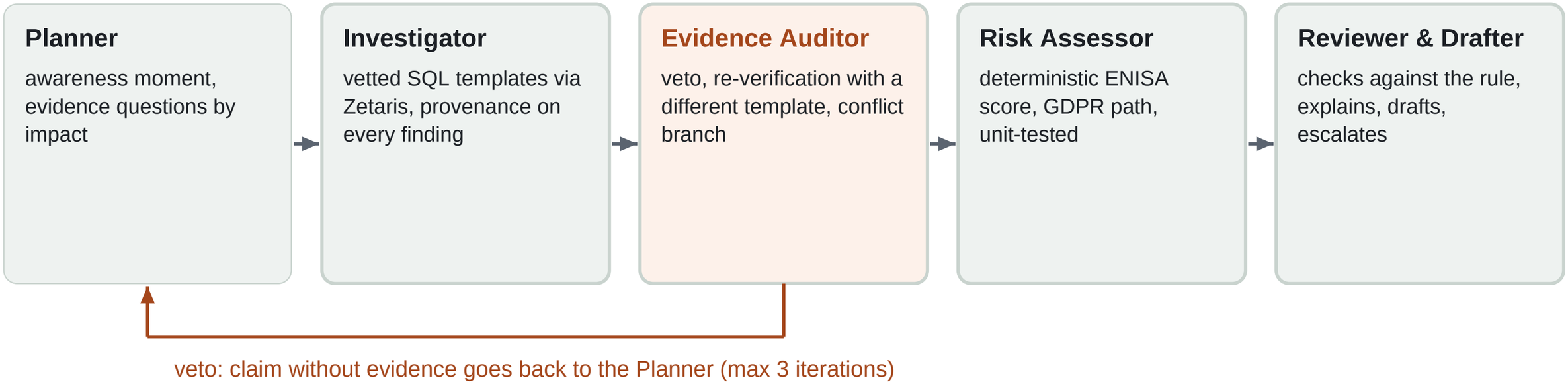
Decision: notify the authority, notify the authority and individuals, document internally, or escalate to the DPO.
Explanation: every line cites finding ids and the legal article.
Draft Art. 33(3) notification and Art. 34 communication.
Open questions and the 72-hour clock (aware at, deadline, hours left).
Full JSONL trace and an HTML report.

What it never does

A language model never makes the decision. A deterministic, unit-tested rule set does (ENISA 2013 severity, GDPR Art. 33 and 34 paths).
No free-form text-to-SQL: only vetted, parameterised query templates.
No claim without evidence: the Evidence Auditor vetoes it.
Decision support for a human, not legal advice. All data is SYNTHETIC.

WORKFLOW

Five agents, one shared case state



- Loops in the trace: veto, re-verification at the source, bounded retry (source 20 s, model 60 s), escalation to the DPO on a borderline score, conflicting sources or an assumed awareness time.
- Shared state: Meterless World Model; every finding and every Auditor status change is a fact with provenance. No provenance, no write.

TECHNOLOGY

Stack: Nemotron explains, the rule decides

NVIDIA Nemotron through the hosted NVIDIA API (integrate.api.nvidia.com):

- Large: nvidia/nemotron-3.5-super-vl-120b-a12b for the Evidence Auditor's conflict note and the Reviewer's plain-language summary.
- Small: nvidia/nemotron-3.5-lightning-30b-a3b for the Planner's investigation note.
- A summary is accepted only if every cited finding exists and it does not contradict the rule's decision; otherwise the deterministic explanation is used and the rejection is logged.

Live run, 23 October 2026, six cases (from the JSONL traces):

agent	model	calls	median latency
evidence_auditor	nvidia/nemotron-3.5-super-vl-120b-a12b	1	0.9 s
planner	nvidia/nemotron-3.5-lightning-30b-a3b	6	1.1 s
reviewer_drafter	nvidia/nemotron-3.5-super-vl-120b-a12b	6	2.6 s

3 transient API errors (timeouts, HTTP 500) in that run, all recovered by bounded retries. Every call is logged with its model; responses are recorded for replay.

Other stack: Python 3.11 standard library only at runtime, pytest, Docker, Cursor.

SPONSOR TECHNOLOGY

Zetaris and Meterless carry the load

Zetaris

Single governed SQL access point to four synthetic systems: incident database, ROPA, asset and encryption register, processor contracts. The Investigator queries in place through vetted templates; the Auditor re-queries with a different template before approval. Adapter with 20 s timeout, bounded retries, recording and replay. Status: adapter implemented and tested; live Zetaris recordings not yet committed, so the offline demo runs the same templates on a local SQLite copy and says so in every output.

Meterless (reference architectures, Apache-2.0)

World Model: the shared case state. Every finding and every Auditor status change is an assertFact with provenance, with an append-only event log.
H-MEM: verified facts about the organisation's registers kept across cases with a JSONL ledger. Recalled facts are re-verified at the source: a match is promoted, a mismatch is superseded. Memory never feeds the rule directly.
Try it: run case 2, then 2b; the second run recalls two facts and re-verifies them.

WHAT IS UNIQUE

Why the explanation can be trusted

- Deterministic, tested severity rule: ENISA 2013, SE = DPC x EI + CB, mapped to GDPR Art. 33(1), 33(2), 33(4), 33(5), 34(1), 34(3)(a), 28(3)(f). Tested on 17 of the 18 worked cases of EDPB Guidelines 01/2021.
- An auditor agent with a veto that re-checks decisive facts (people affected, encryption, disclosure, data categories) at the source with a second query template.
- Organisational memory that is never trusted blindly: every recalled fact is re-verified before use.
- Two gates on model text: citations must exist, and the text must not contradict the decision.
- Honest failure: without data the agents stop with source_unavailable; nothing is invented.

RESULTS

Six synthetic cases, six defensible outcomes

case	decision	severity	time
1 Lost encrypted laptop	document internally (Art. 33(5))	1.0	4 s
2 1 200 records e-mailed to an unknown address	notify authority and individuals	3.5	4 s
2b Same, recipient confirmed deletion	notify the authority	2.5	67 s
3 Ransomware on HR server, sources conflict	escalate to the DPO	5.25	66 s
4 Processor reported after 50 hours	escalate to the DPO	4.0	31 s
5 Discovery time not recorded	escalate to the DPO	3.0	7 s

Case 3 from the output JSON:

Severity 5.25 (very_high) = DPC 4 x EI 1.0 + CB 1.25 (ENISA 2013) [F02][F04][F03].

Escalation: sources conflict on a decisive fact

Open question: Resolve conflict in F03 (disclosure): access log shows outbound transfer of 2,147,483,648 bytes, IT report states no evidence of exfiltration | auditor model note: Packet capture (PCAP) or NetFlow records for traffic to 198.51.100

DEVELOPMENT

How it was built, and its limits

Built in the window (22 to 27 October)

92 automated tests: rule set on EDPB cases, pipeline, Meterless, Nemotron gates, API, replay check.
Clean-clone check with an empty environment: python run.py --all --backend dev gives the same six decisions; Nemotron replays recorded live responses.
Cursor: project rules in .cursor/rules; four documented Cursor Agent sessions (docs/cursor_usage/01-04). Later commits by an AI coding agent outside Cursor are labelled so.
Self-check script: required files, secret scan, recordings, Cursor evidence.

Limitations

Decision support for a DPO, not legal advice.
All data is synthetic (data/SYNTHETIC.md).
Severity follows the ENISA 2013 method; national authority practice may differ.
Category-to-severity mapping is a documented policy, not an official table.
Live Zetaris recordings are pending; the demo uses the local SYNTHETIC SQLite backend.